# Detecting and Stopping Bot Attacks in eCommerce Companion Guide

Revised October 27, 2026

## Lesson 1 Introduction to eCommerce Bot Attacks

Bot attacks are a longstanding yet unresolved issue in eCommerce, growing more sophisticated as attackers automate more of the customer journey. These threats can cause financial damage, disrupt operations, and erode customer trust. Modern malicious automation ranges from simple scripted requests to sophisticated activity that imitates legitimate shopping. AI-assisted tools can help attackers develop or adjust scripts and react to defenses, but not every advanced bot uses AI. Evaluate the specific journey at risk, such as login, account creation, product discovery, inventory reservation, checkout, loyalty redemption, or payment, and compare suspicious activity with business context before labeling it an attack.

## Apply the lesson

- Identify the abused action and its business outcome, not only total traffic.
- Distinguish automated business abuse, botnets, and persistent network intrusion.
- Use evidence rather than assumptions about an operator's income, region, or appearance.
- Assess how controls affect revenue, operating costs, and customer access.

## Decision prompt

Which customer journey is being harmed, and what evidence distinguishes abuse from expected activity?

# Lesson 2

Types of Bot Attacks

Bots are automated programs that can serve either beneficial or harmful purposes online. Good bots help with tasks such as web crawling and monitoring, while bad bots support abuse such as scraping, spamming, credential stuffing, account takeover, loyalty abuse, scalping, DDoS, and payment-card testing. Modern automated abuse can target browser, mobile-app, and API flows, including login, registration, product, inventory, checkout, loyalty, and payment endpoints. Different attacks may share automation techniques but create different business risks, so classification should reflect the affected customer journey and business outcome, not just the presence of automation.

## Apply the lesson

- Separate search, monitoring, AI training, and user-directed agent access.
- A known operator is not blanket authorization for every action or end user.
- Robots.txt communicates preferences; enforce sensitive access separately.
- Protect login, recovery, account creation, inventory, card setup, and payment flows.

## Decision prompt

Which automation should be permitted, and what actions remain restricted?

# Lesson 3

Signs and Symptoms of a Bot Attack

Bot attacks are becoming increasingly sophisticated, making early detection crucial to protect digital infrastructure. Common indicators include sudden shifts in traffic, unusual behavior patterns, repeated failures, abnormal account or payment activity, and changes in customer experience metrics. A spike in pageviews alone does not establish malicious automation. Review request velocity, unusual paths, repeated failures, device and network patterns, account creation rates, checkout completion, payment authorization outcomes, and business context such as marketing campaigns, product launches, and seasonal activity. Sophisticated automation can also occur without a dramatic traffic spike.

## Apply the lesson

- Low-rate, distributed activity may avoid obvious spikes.
- Combine accounts, sessions, request paths, and payment outcomes.
- Consider campaigns, releases, accessibility tools, VPNs, and shared networks.
- Measure false positives, missed abuse, completion, latency, and support contacts.

## Decision prompt

What alternative explanation must be ruled out before enforcement?

# Lesson 4

Traditional Bot Management Techniques

Traditional bot management techniques, such as CAPTCHAs, IP restrictions, deny or allow lists, device signals, and rate limiting, still play an important role in eCommerce defenses. These controls remain useful, but none is a complete safeguard on its own. Distributed actors may rotate IP addresses, CAPTCHA solvers can defeat challenges, and device fingerprints are probabilistic rather than guaranteed identities. Rate limits should be tailored to the endpoint, account, device, network, and business context, with ongoing monitoring for legitimate-customer friction.

## Apply the lesson

- Use limits across relevant accounts, sources, sessions, and endpoints.
- Validate challenge results on a trusted server and reject replay as required.
- Treat user-agent values and device signals as evidence with limits.
- Provide usable alternatives and recovery paths for genuine customers.

## Decision prompt

Which control limits the abusive action while preserving legitimate access?

# Lesson 5

Current Bot Management Solutions

As bot attacks become more advanced, organizations increasingly rely on layered detection and response rather than any single signal or control. Current solutions combine behavior analysis, machine learning, request evaluation, and enforcement across the customer journey. Client-side telemetry can describe browser or app behavior, but data generated on a client may be altered or imitated. Server-side and edge defenses can also respond in real time when the architecture supports it. Effective programs layer request, behavior, identity, transaction, and verified client signals, and they evaluate models for signal quality, drift, false positives, false negatives, and adversarial manipulation.

## Apply the lesson

- Client, server, and edge views are complementary; none guarantees authentic data.
- A fingerprint is probabilistic and a passed challenge does not authorize a payment.
- Monitor drift and labels; evaluate updates and retain a rollback route.
- Test practical agent, privacy, and managed-challenge capabilities before adoption.

## Decision prompt

What evidence would demonstrate that a model or signal is still useful?

# Lesson 6

Strategic Considerations for Bot Management

Strategic bot management involves assessing risks to digital assets, evaluating potential threats, and developing a mitigation plan that balances security, business performance, and customer experience. Use a risk-based decision process: identify the protected customer journey and business impact, monitor relevant signals, choose a proportionate action, and measure both fraud reduction and legitimate-customer friction. Responses may range from observation and slowing requests to targeted challenges, step-up verification, or blocking clearly abusive activity. Assign owners across security, fraud, payments, operations, and customer experience.

## Apply the lesson

• Assign response owners across fraud, payments, engineering, support, and privacy.

• Choose a lawful basis for personal-data processing and assess device-access rules separately.

• Fraud prevention is not a blanket consent exemption.

• Minimize data, protect access and transfers, define retention, and offer applicable recourse.

## Decision prompt

Who owns the response, data responsibilities, and customer escalation?

# Lesson 7

Partnering with Solution Providers

Choosing the right bot management solution is crucial for protecting your business from evolving bot threats. Strong providers support layered detection, adaptable enforcement, reliable reporting, and collaborative operational support. A representative proof of concept should cover browser, mobile-app, and API traffic. Evaluate documented detection methodology, false positives and negatives, customer friction, reporting, incident support, adaptability, integrations, privacy, data retention, availability, and exit requirements. Prefer the provider that demonstrates better risk-adjusted protection in your environment rather than the one promising the largest unverified percentage.

## Apply the lesson

- Pilot browser, app, and API traffic, including missing telemetry and approved automation.
- Measure demonstrated protection and customer friction against a baseline.
- Keep merchant ownership of policy; control, test, and log tuning changes.
- Review outages, rollback, data responsibilities, SOC 2 report scope, and exit planning.

## Decision prompt

What will the pilot measure, and how will a failed change be reversed?

# Control comparison

Use a combination suited to the protected action

## Rate limits

Control repeated activity across relevant keys. Per-IP limits alone can miss distributed abuse.

## Network and device evidence

Useful for patterns and correlation; shared environments, changes, and imitation limit certainty.

## Managed checks and challenges

Validate results on the server. Measure accessibility, abandonment, and customer fallback.

## Authentication and payment controls

Verify account or transaction requirements at the protected action. A bot score does not establish authorization.

## Models and behavioral rules

Evaluate representative data, false positives, missed abuse, and drift. Use staged releases and rollback.

# Risk assessment worksheet

Complete with the teams responsible for the journey

## Protected journey and business owner

## Abuse mechanism and available evidence

## Customer and financial impact

## Expected legitimate behavior and exceptions

## Proposed response and escalation owner

## Necessary data and privacy review

## Success measures and rollback condition

# Control pilot and action plan

Agree the baseline before broad enforcement

## Pilot scope across browser app and API

## Known abuse and genuine-customer test cases

## Baseline and post-change metrics

## Accessibility and missing-telemetry tests

## Outage behavior and rollback owner

## Vendor data export deletion and exit plan

## Next actions owners and review date

# Glossary and sources

Use these definitions when reviewing outcomes

False positive: Legitimate activity restricted by the control.

False negative: Abusive activity missed by the control.

Drift: A change in data or relationships that can alter model performance.

Attestation: Evidence supporting a limited claim under an issuer policy.

Authorization: Permission for a particular action; recognizing an operator alone does not grant it.

Pseudonymization: Reducing direct identifiability without necessarily making data anonymous.

## Selected references


OWASP - Bot Management and Anti-Automation

OWASP - Credential Stuffing Prevention

W3C - Inaccessibility of CAPTCHA

IETF - RFC 9309 Robots Exclusion Protocol

Cloudflare - Verified bots and agents

Cloudflare - Server-side challenge validation

Stripe - Card testing

EDPB - Legal basis

ICO - Cookies and similar technologies